

# When Do Training-Time Attacks on Malware Classifiers Actually Hold Up? Evaluating the Reliability of Selective Backdoors Beyond Controlled Settings

Guanyu Hou

Research Proposal

## Lay Summary

Security companies increasingly rely on machine learning to decide whether a file is malware. Because malware changes constantly, these systems are retrained on files gathered from the internet, which gives an attacker an opening: by contributing a small number of prepared files, an attacker can plant a hidden flaw, a backdoor, in the retrained model. One recent attack does this *selectively*, teaching the model to overlook a single attacker’s own malware while still catching everyone else’s, and it is hard to detect. It works because malware written by the same author tends to resemble itself, and the attack hides inside that resemblance. This project asks how far that resemblance can be relied upon: whether the attack still succeeds when malware is described in a different way, when it comes from a different platform such as Windows rather than Android, and when the system is tested on malware newer than what it was trained on, as it would be in practice. The result shows where the threat is real and where it is an artefact of convenient test conditions, and this understanding is used to design detection aimed at this overlooked, selective form of attack.

## What Excites Me

A recurring difficulty in security research is that an attack, or a defence, can look convincing inside the controlled experiment that introduced it and behave very differently once the setting changes. To me this gap is the substance of the problem, not a detail: a vulnerability that holds only under favourable conditions is a different vulnerability from one that survives realistic deployment. Selective backdoors against malware classifiers are the sharpest current example, effective as reported yet resting on a specific and largely untested assumption about the data. What draws me to this is that deciding whether the assumption holds is a question not of a stronger attack, but of disciplined evaluation, which is exactly the kind of question my own work on the robustness of learning-based models has repeatedly turned on.

## 1. Introduction

Machine-learning classifiers are increasingly deployed in real-world malware detection, where they scale to volumes that manual, signature-based analysis cannot match [7]. Because malware evolves continuously, these classifiers are retrained on samples collected from the wild, which opens a training-time attack surface: an adversary who is able to contribute data can attempt to poison the model [2]. The most concerning form of this is the backdoor attack, and its stealthiest current variant is the *selective* backdoor. Jigsaw Puzzle [1] protects only the attacker’s own malware family while leaving other malware detectable, and it evades class-level defences because those defences assume a trigger flips an entire class.

Prior work has established that such attacks are feasible and stealthy, but their effectiveness rests on an assumption that has not been tested outside a narrow setting: that malware from the same family shares enough latent structure for a family-specific trigger to be learned. Selective backdoors have so far been demonstrated mainly on Android, on one feature representation (Drebin-style binary features), on shallow models, and under random train/test splits. As a result, it remains unknown whether the threat is a general

property of malware classifiers or an artefact of these convenient experimental conditions. This distinction has practical consequences: a defender who cannot tell the two apart may spend effort where the threat is not real and overlook it where it is. This proposal therefore sets out to characterise *when* selective, training-time backdoors against malware classifiers actually remain effective across feature representations, binary types, and realistic, time-aware evaluation, and to use that understanding to design defences aimed at subset-level rather than class-level backdoors.

## 2. Background and Related Work

Three lines of prior work bear directly on this proposal: backdoor attacks against malware classifiers, defences against them, and the broader question of evaluation realism in malware classification.

**Backdoor attacks on malware classifiers.** Backdoor attacks were first studied extensively in vision and language, but transferring them to malware classifiers introduces two constraints: *realizability* (the trigger must not break the sample’s malicious functionality) and the *clean-label* setting (the attacker cannot relabel poisoned data) [2, 1]. Severi et al. [2] use explanation methods to select realizable trigger features. Yang et al. [1] improve stealth by making the backdoor *selective* and realising it in the problem space via bytecode gadgets, building on the problem-space attack framework of Pierazzi et al. [6]. This line of work remains active: recent studies continue to construct clean-label backdoors against static malware detectors, including on Windows PE binaries [11]. The underlying threat is therefore not tied to the original Android/Drebin setting, which makes the generality of the *selective* variant a natural open question.

**Backdoor defences.** Detection operates at the level of inputs, datasets, or models. Model-level meta-classifier defences such as MNTD [3] are among the strongest, yet they, like most defences, assume the trigger affects an entire class, an assumption selective backdoors deliberately violate. A recent post-training method, PBP [8], takes a different route: instead of detecting a trigger, it removes the backdoor from an already-trained model without assuming a specific trigger mechanism, and reports neutralising even Jigsaw Puzzle in its original setting. This is an important advance, but two questions remain open. First, PBP *purifies* a given model rather than *detecting* whether a subset-level backdoor is present, which is the task a defender faces when screening many models, so a detector aimed at subset-level triggers is still missing. Second, like the attacks it counters, PBP has so far been assessed on the standard Android/Drebin setup under random splits, so its behaviour across feature representations, binary types, and temporal drift is untested. The gap between the attacker’s subset-level granularity and the defender’s assumptions therefore persists.

**Evaluation realism in malware classification.** A parallel line of work argues that malware-classification results are frequently inflated by experimental bias. TESSERACT [4] shows how ignoring temporal ordering produces optimistic estimates, and work on concept drift [5] studies how classifiers degrade as malware evolves. Recent work makes this concern concrete for the very assumption the selective backdoor depends on. LAMDA [9], a longitudinal Android benchmark spanning 2013 to 2025, shows that per-family feature stability and feature relevance shift substantially over time. In other words, the intra-family similarity that a family-specific trigger exploits is itself time-dependent. In the Windows PE setting, Li et al. [10] similarly find that graph-based classifiers degrade under drift and must learn drift-invariant features to recover, which indicates that both the representation and the temporal protocol affect what a classifier learns about a family.

**Research gap.** Taken together, these lines leave a specific gap. The selective-backdoor threat has been shown only under a narrow set of conditions, and on some families only with per-family tuning, yet the assumption it depends on, intra-family similarity, is exactly the kind of property the evaluation-realism literature shows can weaken outside those conditions. It therefore remains open *under what conditions* the threat actually holds, and how a defender should respond once it does. To the author’s knowledge, the evaluation-realism lens has not previously been applied to selective backdoor attacks. The research questions below make this gap precise.

### 3. Aims and Research Questions

The central aim is to characterise *when* selective, training-time backdoors against malware classifiers remain effective, to establish this under realistic evaluation, and to use the resulting understanding to build defences targeted at subset-level (rather than class-level) backdoors. The project is organised around three research questions:

- **RQ1 (Mechanism & Generality).** The selective backdoor relies on intra-family similarity. To what extent does its effectiveness persist across different feature representations (beyond Drebin-style binary features), different binary types (e.g., PE as well as Android), and more expressive models (e.g., graph- or sequence-based classifiers)?
- **RQ2 (Evaluation Realism).** How does the measured threat change under realistic evaluation, in particular temporal splits and concept drift over time, rather than the random splits under which such attacks are typically reported? Where does the apparent effectiveness shrink, and where does it survive?
- **RQ3 (Targeted Defence).** Can a defence that explicitly assumes a *subset-level* trigger detect selective backdoors that class-level defences miss, and does it survive an adaptive attacker who splits a family into sub-families or protects only newly released variants?

### 4. Methodology and Experimental Design

The three research questions share one experimental need: a platform that varies the feature representation, the model, the binary type, and the evaluation protocol *independently*, so that any change in the selective backdoor’s effectiveness can be attributed to a specific factor rather than to a confound. This section sets out that design. The research plan (Section 5) then sets out how it is executed, beginning with a concrete six-month starting project.

**Threat model.** This proposal adopts the clean-label, poisoning-only setting of Jigsaw Puzzle [1]. The attacker contributes a small fraction of the training data as poisoned samples, cannot relabel data, cannot change the training procedure or the model, and has no access to test-time inputs. The goal is *selective*: the attacker’s own target family evades detection when the trigger is present, while detection of other malware and accuracy on clean samples are left unchanged, so that the backdoor stays stealthy. For RQ3, two attacker variants are considered: a *static* attacker with a fixed target family, and an *adaptive* attacker who splits a family into sub-families or protects only newly released variants in order to evade a subset-level defence. Poisoning budget and realizability constraints are held consistent across settings so that comparisons remain fair.

**Datasets.** On Android, the study draws on Drebin [7] and AndroZoo [12] for the original setting and for temporal coverage, and on LAMDA [9] for longitudinal (2013 to 2025) family-level drift. On Windows PE, it uses BODMAS [13] and EMBER [14], both timestamped and with curated family labels, to test whether the mechanism transfers to a different binary type. Timestamps are essential: they make it possible to build temporal splits for RQ2 rather than random ones.

**Feature representations and models (RQ1).** The representation is varied along a spectrum of expressiveness. The first is Drebin-style binary feature vectors with shallow models (linear SVM, random forest, gradient-boosted trees), which reproduces the original baseline. The second is API- and function-call graphs classified by graph neural networks, following recent drift-robust designs [10]. The third is raw byte or opcode sequences classified by convolutional or sequence models such as MalConv [15]. Holding the attack fixed while moving across these representations tests whether intra-family similarity, the property the trigger exploits, survives a richer encoding, or whether it is partly an artefact of the sparse binary features on which the attack was first shown.

**Evaluation protocol (RQ2).** Random splits are replaced with time-aware splits: the model is trained on earlier samples and tested only on strictly later ones, following TESSERACT [4]. Robustness over time is reported with the Area-Under-Time (AUT) metric [4], and increasing drift is simulated by widening the gap

between the training and test periods. For each configuration the backdoor is measured under both protocols, and the difference is treated as the portion of the reported effectiveness that is attributable to the evaluation setup rather than to the attack itself.

**Metrics.** Four quantities are reported together. The first is the attack success rate on the target family, the fraction of triggered target-family malware misclassified as benign. The second is the collateral leakage onto non-target malware, which should stay near zero for a genuinely selective backdoor. The third is the clean-task performance, measured as F1 on unpoisoned data. The fourth is the detectability by defences, including MNTD [3] and the subset-level detector described below. Reporting all four prevents a partial picture. For instance, a high attack success rate obtained at the cost of clean accuracy is not the stealthy threat the attack claims to be.

**Defence design (RQ3).** The working hypothesis is that a subset-level backdoor leaves a subset-level signature: within the target class, the protected family forms a group whose latent representations move together toward the benign side when the trigger is present, in a way the rest of the class does not. Class-level defences average this signal away, which is why selective backdoors evade them. A defence that looks for anomalies at the granularity of a *subset* should be able to recover it. This proposal will adapt latent-space methods that already separate poisoned from clean data at the class level, namely spectral signatures [16] and activation clustering [17], and apply them within candidate sub-populations rather than across an entire class, using family labels where available and unsupervised clustering where they are not. Recent detectors are beginning to move in a compatible direction: TellTale [18], for example, identifies poisoned samples from their training-trajectory spectrum and reports handling *partial* backdoors without a reserved clean set. Such methods are general-purpose and have not been evaluated on malware classifiers or under temporal drift, which is precisely the gap this project addresses: a detector aimed at subset-level triggers, tested in the malware setting and under realistic evaluation. The resulting detector is then stress-tested against the adaptive attacker from the threat model: if splitting a family or protecting only new variants defeats it, that failure mode itself characterises the limits of subset-level detection and directs the next iteration. Success is measured by the detection rate at a fixed false-positive budget, and by how much the adaptive attacker must weaken its own attack (a lower poisoning rate or a smaller protected set) in order to evade detection.

**Reproducibility.** The project will build on the released Jigsaw Puzzle artefact as the baseline and release the modular platform, so that every result can be traced to a single controlled change rather than to differences in implementation.

## 5. Starting Project and Timeline

The PhD would begin with a self-contained six-month project that establishes the baseline, builds the experimental platform, and delivers a first result: whether the selective-backdoor mechanism generalises beyond its original Android/Drebin setting, and whether it survives a first time-aware evaluation. This scope corresponds to RQ1 and the first part of RQ2, and is intended to be publishable in its own right while providing the tooling for the remainder of the PhD. Each step isolates one axis of the experimental design in Section 4, so that any observed change can be attributed to a single controlled factor.

- **Months 1–2: Reproduction and platform.** Reproduce the selective backdoor on the original Android/Drebin setup using the released Jigsaw Puzzle artefact, and build the modular pipeline that decouples feature representation, model, and evaluation protocol, so that each axis can subsequently be varied in isolation.
- **Months 3–4: Generality (RQ1).** Hold the attack fixed and move across representations (graph- and sequence-based) and to Windows PE malware, measuring how intra-family similarity and attack effectiveness change and isolating which factor drives success.
- **Month 5: First evaluation-realism check (RQ2).** Re-run the strongest configurations under temporal rather than random splits, and treat the gap between the two as the portion of the reported effectiveness

attributable to the evaluation setup.

- **Month 6: Analysis and write-up.** Consolidate the results into a first characterisation of the conditions under which the attack holds, prepare a paper, and specify the subset-level defence (RQ3) that the rest of the PhD will develop.

**Trajectory beyond the first six months.** The remainder of the PhD extends the evaluation-realism study to longitudinal drift across the full 2013–2025 span (RQ2), develops and stress-tests the subset-level detector against adaptive attackers (RQ3), and consolidates the platform and findings into further publications and the thesis.

## 6. Expected Contributions

- **Empirical:** the first characterisation of the conditions (representation, binary type, and evaluation protocol) under which selective backdoors against malware classifiers remain effective.
- **Methodological:** an open, modular evaluation platform that separates representation, model, and protocol, enabling realistic (drift-aware) assessment of training-time attacks.
- **Defensive:** a detection approach targeted at subset-level backdoors, evaluated against adaptive attackers.

## 7. Ethics and Responsible Research

Because this proposal studies attacks as well as defences, it follows established norms for dual-use security research. The purpose throughout is defensive: attacks are reproduced and varied only to characterise where the threat is real and to build detection against it, and the intended output of the project is a defence, not a more capable attack.

**Data and containment.** All experiments use established, publicly released research datasets (Drebin, AndroZoo, BODMAS, EMBER, and LAMDA) under their respective terms of use, rather than newly harvested malware, which avoids creating or distributing new malicious samples. Malware is handled only in isolated, non-networked environments and is never executed outside controlled analysis. Models are trained solely on these datasets and are never deployed against live systems or third-party detection services.

**Responsible disclosure and release.** Should the work show that a deployed or commercial classifier is vulnerable in a previously unreported way, the findings will be disclosed to the affected parties before publication, following the coordinated-disclosure norms of the target venues. Released artefacts are calibrated accordingly: the evaluation platform and the defence will be shared to support reproducibility and follow-on defensive work, while attack components are documented at the level needed to reproduce results rather than as turnkey tooling that would lower the barrier to real-world misuse.

**Oversight.** The research will be conducted under the host institution’s research-ethics and governance procedures, and the balance between openness and potential for misuse will be reviewed at each release rather than settled once at the outset.

## References

- [1] L. Yang, Z. Chen, J. Cortellazzi, F. Pendlebury, K. Tu, F. Pierazzi, L. Cavallaro, and G. Wang. Jigsaw Puzzle: Selective Backdoor Attack to Subvert Malware Classifiers. *IEEE S&P*, 2023.
- [2] G. Severi, J. Meyer, S. Coull, and A. Oprea. Explanation-Guided Backdoor Poisoning Attacks Against Malware Classifiers. *USENIX Security*, 2021.
- [3] X. Xu, Q. Wang, H. Li, N. Borisov, C. A. Gunter, and B. Li. Detecting AI Trojans Using Meta Neural Analysis. *IEEE S&P*, 2021.
- [4] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro. TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time. *USENIX Security*, 2019.

- [5] R. Jordaney, K. Sharad, S. K. Dash, Z. Wang, D. Papini, I. Nouretdinov, and L. Cavallaro. Transcend: Detecting Concept Drift in Malware Classification Models. *USENIX Security*, 2017.
- [6] F. Pierazzi, F. Pendlebury, J. Cortellazzi, and L. Cavallaro. Intriguing Properties of Adversarial ML Attacks in the Problem Space. *IEEE S&P*, 2020.
- [7] D. Arp, M. Spreitzenbarth, M. Hübner, H. Gascon, K. Rieck, and C. Siemens. Drebin: Effective and Explainable Detection of Android Malware in Your Pocket. *NDSS*, 2014.
- [8] D. T. Nguyen, N. N. Tran, T. T. Johnson, and K. Leach. PBP: Post-Training Backdoor Purification for Malware Classifiers. *NDSS*, 2025.
- [9] M. A. Haque, I. Hossain, M. M. Kamol, M. J. Alam, S. K. Amalapuram, S. Talukder, and M. S. Rahman. LAMDA: A Longitudinal Android Malware Benchmark for Concept Drift Analysis. *arXiv:2505.18551*, 2025.
- [10] A. S. Li, A. Iyengar, A. Kundu, and E. Bertino. Revisiting Concept Drift in Windows Malware Detection: Adaptation to Real Drifted Malware with Minimal Samples. *NDSS*, 2025.
- [11] D. Zhan, K. Xu, X. Liu, T. Han, Z. Pan, and S. Guo. Practical Clean-Label Backdoor Attack Against Static Malware Detection. *Computers & Security*, 150:104280, 2025.
- [12] K. Allix, T. F. Bissyandé, J. Klein, and Y. Le Traon. AndroZoo: Collecting Millions of Android Apps for the Research Community. *Mining Software Repositories (MSR)*, 2016.
- [13] L. Yang, A. Ciptadi, I. Laziuk, A. Ahmadzadeh, and G. Wang. BODMAS: An Open Dataset for Learning based Temporal Analysis of PE Malware. *Deep Learning and Security Workshop (DLS)*, 2021.
- [14] R. J. Joyce, R. Zak, G. Miller, E. Zaresky-Williams, P. Roth, H. Anderson, and E. Raff. EMBER2024: A Benchmark Dataset for Holistic Evaluation of Malware Classifiers. *arXiv:2506.05074*, 2025.
- [15] E. Raff, J. Barker, J. Sylvester, R. Brandon, B. Catanzaro, and C. Nicholas. Malware Detection by Eating a Whole EXE. *AAAI Workshops*, 2018.
- [16] B. Tran, J. Li, and A. Madry. Spectral Signatures in Backdoor Attacks. *NeurIPS*, 2018.
- [17] B. Chen, W. Carvalho, N. Baracaldo, H. Ludwig, B. Edwards, T. Lee, I. Molloy, and B. Srivastava. Detecting Backdoor Attacks on Deep Neural Networks by Activation Clustering. *AAAI Workshop*, 2019.
- [18] Y. Gao, H. Peng, H. Ma, Z. Zhang, S. Wang, R. Holland, A. Fu, M. Xue, and D. Abbott. Try to Poison My Deep Learning Data? Nowhere to Hide Your Trajectory Spectrum! *NDSS*, 2025.